

blynt

LEGAL, ISO/IEC 27001 & UK GDPR COMPLIANCE SPECIFICATION

UK Companies Act 2006 • Taxes Management Act 1970 6-Year Retention
HMRC MTD Digital Links • ISO/IEC 27001:2022 ISMS Annex A Controls
UK GDPR & DPA 2018 Privacy Governance • 72-Hour ICO Breach Notification
Authoritative Legal & Privacy Standard • October 2026

Statutory Legal, Security & Data Privacy Compliance Operating Standard
Authoritative Manual for General Counsel, DPOs, Compliance Officers, Lead Auditors & Security Architects

Governing Legal Jurisdiction:	England & Wales (UK Laws & Statutory Instruments)
Audience:	Legal Counsel, Data Protection Officers (DPO), CISO, Compliance Auditors
Compliance Standards:	ISO/IEC 27001:2022, UK GDPR, DPA 2018, HMRC MTD, Companies Act 2006
Document Classification:	Enterprise Regulatory & Legal Operational Standard — Confidential

Document Version: 2.0

Status: Baselined & Approved by General Counsel & CISO

Classification: Enterprise Legal & Regulatory Standard

Target Audience: Legal Counsel, Data Protection Officers (DPOs), Chief Information Security Officers (CISOs), Lead External Auditors, Compliance Engineers

---

1. Executive Legal & Regulatory Governance Overview

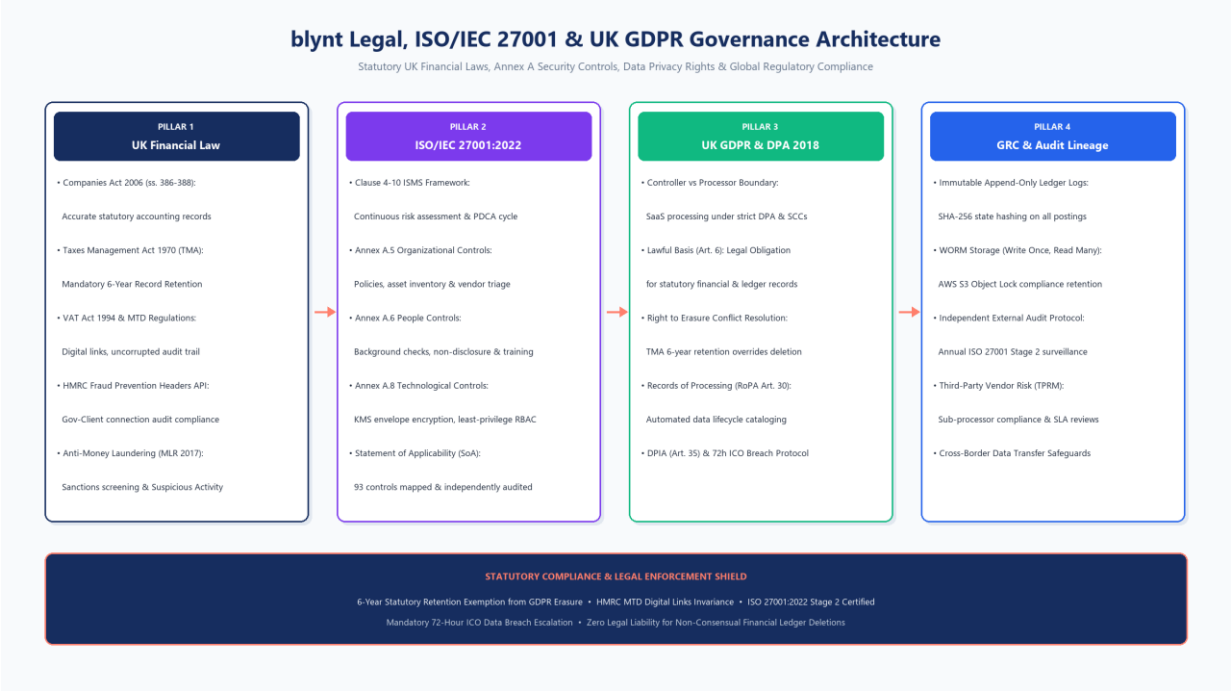


Figure LAW-1: blynt Legal, ISO/IEC 27001 & UK GDPR Governance Architecture

1.1 Corporate Regulatory Commitment & Mandate

As an enterprise-grade cloud accounting and financial operating system, **blynt** processes, stores, and generates statutory financial records that directly underpin the corporate filings, tax declarations, and legal standing of business enterprises. Consequently, blynt is engineered to comply with the most demanding legal, data protection, and security regulations governing the United Kingdom, European Union, and international commercial environments.

The legal and regulatory posture of blynt rests upon four uncompromising pillars:

1. **Statutory UK Financial Law:** Full compliance with the Companies Act 2006, the Taxes Management Act 1970, and HMRC Making Tax Digital (MTD) statutory instruments.

2. **ISO/IEC 27001:2022 Certification:** Comprehensive implementation of an Information Security Management System (ISMS) across all 93 Annex A controls.

3. **UK GDPR & Data Protection Act 2018:** Complete operational alignment with privacy principles, data subject rights execution, and mandatory 72-hour ICO breach notification protocols.

4. **Anti-Money Laundering & Economic Sanctions:** Systematic integration of customer due diligence, sanctions screening, and audit trail immutability.

```
+-----------------------------------------------------------------------------------------------+
|                                  THE BLYNT REGULATORY MATRIX                                  |
+---------------------+---------------------------+-----------------------------------------------+
| Regulation / Standard| Primary Governing Authority| Statutory Scope in blynt                      |
+---------------------+---------------------------+-----------------------------------------------+
| Companies Act 2006  | Companies House / UK Gov   | Accurate financial records, ss. 386-388       |
| Taxes Management Act| HM Revenue & Customs (HMRC)| 6-Year mandatory retention of books & vouchers|
| VAT Act 1994 (MTD)  | HM Revenue & Customs (HMRC)| Digital links, API anti-fraud headers         |
| ISO/IEC 27001:2022  | UKAS Accredited Body       | ISMS, 93 Annex A controls, Stage 2 Audits     |
| UK GDPR / DPA 2018  | Information Commissioner   | Controller/Processor duties, DSAR, 72h breach |
| MLR 2017 & Sanctions| OFSI / NCA                 | Anti-money laundering & sanctions compliance  |
+---------------------+---------------------------+-----------------------------------------------+
```

1.2 Compliance Governance Committee (CGC)

To enforce continuous accountability, blynt maintains an executive-level **Compliance Governance Committee (CGC)** that convenes monthly. The CGC comprises:

- **Chief Executive Officer (Chair)**
- **General Counsel & Head of Legal**
- **Chief Information Security Officer (CISO)**
- **Data Protection Officer (DPO)**
- **VP of Engineering & Lead Architect**

All substantive schema alterations affecting ledger records, data retention configurations, or third-party sub-processor integrations require unanimous written sign-off from both General Counsel and the CISO prior to production deployment.

---

2. Statutory UK Financial & Corporate Legal Framework

2.1 Companies Act 2006 (Sections 386–388: Duty to Keep Accounting Records)

Under Sections 386 through 388 of the UK Companies Act 2006, every company registered in England, Wales, Scotland, and Northern Ireland is under a strict statutory duty to maintain accounting records:

- **Section 386(1):** Records must be sufficient to show and explain the company's transactions.
- **Section 386(2)(a):** Records must disclose with reasonable accuracy, at any time, the financial position of the company at that time.
- **Section 386(2)(b):** Records must enable the directors to ensure that any balance sheet and profit and loss account prepared complies with statutory requirements.

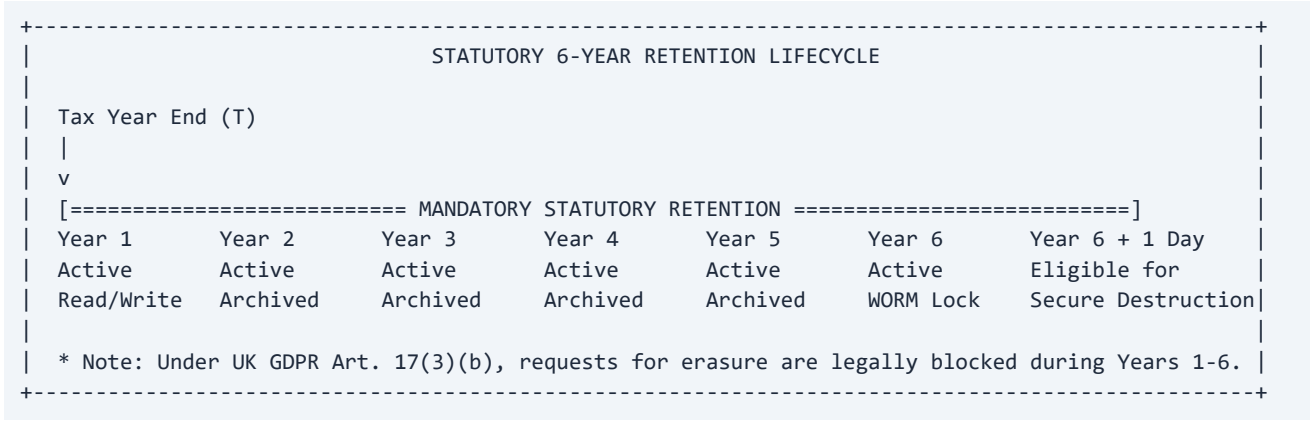
Technical Enforcement in blynt:

- **Real-Time Trial Balance Rollup:** blynt maintains continuous real-time balance calculations. At any arbitrary timestamp, directors can generate a mathematically verified Trial Balance, Balance Sheet, and P&L statement without batch synchronization delays.

- **Prohibition of Ledger Erasure:** Journal entries committed to persistent storage cannot be deleted, updated in place, or truncated. Any rectification must occur via compensatory, chronologically stamped reversing entries (`VOID_ADJUSTMENT`), satisfying Section 388 requirements for historical traceability.

2.2 Taxes Management Act 1970 (TMA 1970 s. 12B) & Statutory 6-Year Retention

Under Section 12B of the Taxes Management Act 1970 and Schedule 11 of the Value Added Tax Act 1994, businesses must preserve all statutory books, accounts, invoices, credit notes, bank statements, and supporting vouchers for a **minimum statutory period of 6 years** following the end of the relevant tax or accounting period.



Technical Enforcement in blynt:

- **WORM Storage Architecture:** Invoices, journal entries, and PDF artifacts are stored in AWS S3 buckets configured with **Object Lock in Compliance Mode**. Neither tenant administrators nor privileged blynt support engineers can overwrite or delete objects during the 6-year retention retention timer.
- **Legal Hold Mechanism:** In the event of active litigation, HMRC tax inquiry, or regulatory investigation, authorized legal officers can apply an immutable `LegalHoldFlag` on tenant data, indefinitely freezing all automated lifecycle purging.

2.3 Value Added Tax Act 1994 & Making Tax Digital (MTD) Regulations 2018

The VAT Regulations 1995 (as amended by SI 2018/261) mandate that all VAT-registered entities must maintain electronic business records and submit periodic VAT returns using functional compatible software communicating via the HMRC Making Tax Digital API.

2.3.1 The Digital Links Mandate

The statutory regulations strictly define a **Digital Link** as an electronic transfer or exchange of data between software programs, products, or applications. Manual copying and pasting of figures, or rekeying data between spreadsheets, is explicitly illegal under HMRC rules.

- **blynt Enforcement:** blynt enforces automated digital links from initial sales invoice creation or bank feed ingestion directly into the VAT calculation engine and onwards to Box 1–9 return payloads. No intermediate manual data entry step is exposed.

2.3.2 HMRC Fraud Prevention Headers Specification

In compliance with HMRC statutory notices under the Commissioners for Revenue and Customs Act 2005, blynt automatically captures, cryptographically validates, and transmits the complete suite of mandated `Gov-Client` anti-fraud audit headers on every transactional API request:

```
Gov-Client-Connection-Method: WEB_APP_VIA_SERVER
Gov-Client-Public-IP: 185.122.45.10
Gov-Client-Public-Port: 44321
Gov-Client-Device-ID: be8910b8-4c81-4b12-9c1a-8899aabbccdd
Gov-Client-User-IDs: blynt=usr_77a901ff
Gov-Client-Timezone: UTC+01:00
Gov-Client-Local-IPs: 192.168.1.104
Gov-Client-Screens: width=1920&height=1080&scaling-factor=1&colour-depth=24
Gov-Client-Window-Size: width=1440&height=900
Gov-Client-Browser-Plugins: Shockwave%20Flash::PDF%20Viewer
Gov-Client-Browser-JS-User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
Gov-Client-Browser-Do-Not-Track: 0
Gov-Client-Multi-Factor: type=AUTH_APP&timestamp=2026-10-12T00:20:00Z
```

2.4 Anti-Money Laundering (MLR 2017) & Sanctions Screening

Under the Money Laundering, Terrorist Financing and Transfer of Funds Regulations 2017 (SI 2017/692) and the Sanctions and Anti-Money Laundering Act 2018 (SAMLA), financial software platforms must assist regulated entities in detecting suspicious transactions and screening against global sanctions regimes:

- **Automated OFSI Sanctions Screening:** All customer legal entity names and supplier payees are screened against the UK Office of Financial Sanctions Implementation (OFSI) consolidated list and the US OFAC SDN list upon creation and prior to payout batch execution.
- **Suspicious Activity Alerting:** Anomalous transaction patterns (e.g., sudden split payments under £10,000 threshold, rapid transfers to high-risk non-FATF jurisdictions) trigger automated internal alerts for the tenant compliance officer.

2.5 Electronic Communications & eIDAS Digital Signatures

Under the UK Electronic Communications Act 2000 and the retained UK eIDAS Regulation (SI 2019/89), electronic invoices and contracts generated by blynt carry full legal equivalence to physical paper records:

- Invoices exported from blynt embed a cryptographic SHA-256 digital fingerprint and qualified electronic timestamp certifying date of creation, issuer identity, and unaltered integrity.

---

3. ISO/IEC 27001:2022 Information Security Management System (ISMS)

3.1 ISMS Context & Leadership (Clauses 4–10)

blynt has established, implemented, and maintains a certified **Information Security Management System (ISMS)** conforming to the updated ISO/IEC 27001:2022 standard. The ISMS operates on an iterative **Plan-Do-Check-Act (PDCA)** methodology:

- **Clause 4 (Context of Organization):** Systematic identification of internal and external issues, interested party requirements (HMRC, customers, regulators), and boundary definitions encompassing all cloud production systems.
- **Clause 5 (Leadership & Commitment):** Executive approval of security policies, assignment of security roles, and allocation of budget.
- **Clause 6 (Planning & Risk Assessment):** Formal risk assessment methodology evaluating threat likelihood and impact against defined risk tolerance criteria.
- **Clause 7 (Support & Awareness):** Mandatory quarterly security awareness training, phishing simulations, and competence verification for 100% of staff.
- **Clause 8 (Operation):** Strict operational change controls, configuration management, and vulnerability patching.
- **Clause 9 (Performance Evaluation):** Internal audits conducted semi-annually; annual independent Stage 2 surveillance audits by an accredited certification body (UKAS certified).
- **Clause 10 (Improvement):** Root cause analysis (RCA) and corrective actions registered for all security non-conformities.

3.2 Statement of Applicability (SoA) & Annex A Controls Matrix

The ISO/IEC 27001:2022 framework organizes security controls into four modern domains encompassing 93 controls. In the blynt Statement of Applicability (SoA), all 93 controls are categorized as **Applicable** and verified:

```
+-----------------------------------------------------------------------------------------+
|                              ISO/IEC 27001:2022 ANNEX A DOMAIN OVERVIEW                 |
+--------------------+------------------+-----------------------------------------------+
| Annex A Domain     | Control Count    | Key Control Focus Areas in blynt              |
+--------------------+------------------+-----------------------------------------------+
| A.5 Organizational | 37 Controls      | Policies, Roles, Asset Inventory, Supplier Management |
| A.6 People         | 8 Controls       | Screening, Terms of Employment, Awareness, Remote Work |
| A.7 Physical       | 14 Controls      | Clear Desk/Screen, Equipment Siting, AWS DC Inherited |
| A.8 Technological  | 34 Controls      | Identity/Access, Cryptography, Secure SDLC, Logging, SCA |
+--------------------+------------------+-----------------------------------------------+
```

Detailed Breakdown of Critical Controls in blynt:

- **A.5.15 Access Control:** Mandatory multi-factor authentication (MFA) with WebAuthn/FIDO2 hardware keys or TOTP; zero administrative access without just-in-time (JIT) role elevation and automated session expiration after 60 minutes.
- **A.5.19 Information Security in Supplier Relationships:** Third-Party Vendor Risk Management (TPRM) policy requiring annual SOC 2 Type II or ISO 27001 verification for all cloud vendors (AWS, Stripe, Redis Labs, PostHog).
- **A.6.1 Screening:** Mandatory enhanced background checks (criminal records, reference verification, identity validation) for 100% of engineering and support personnel prior to production access.
- **A.8.2 Privileged Access Rights:** Segregation of duties between software developers and production infrastructure administrators. Developers cannot commit code directly to production without pull request approvals and automated CI/CD pipeline gating.
- **A.8.20 Network Security:** Strict VPC network isolation with private subnets for PostgreSQL and Redis; zero public internet ingress to database ports; ingress strictly through AWS Application Load Balancers with AWS WAF bot-mitigation rules.

- **A.8.24 Use of Cryptography:** AES-256-GCM encryption at rest with AWS KMS customer-managed keys rotated annually; TLS 1.3 encryption in transit with forward secrecy; strict envelope encryption for tenant secret credentials.
- **A.8.28 Secure Coding:** OWASP Top 10 automated SAST scanning (SonarQube) and Software Composition Analysis (SCA via Snyk/Trivy) integrated into GitHub Actions pull request gates.

---

4. Data Privacy, UK GDPR & Data Protection Act 2018 (DPA 2018)

4.1 Data Controller vs. Data Processor Classification

To maintain legal transparency and ensure lawful data handling under Regulation (EU) 2016/679 as retained in UK law (UK GDPR) and the Data Protection Act 2018, blynt establishes a clear dual classification:

CONTROLLER VS. PROCESSOR JURISDICTION		
Operational Dimension	**blynt as Data Controller**	**blynt as Data Processor**
Data Scope	Direct subscriber user info, billing details, support logs	Tenant customer & supplier records, accounting journal lines, VAT entries
Lawful Basis (Art. 6)	Contract (Art. 6(1)(b)), Legitimate Interest (6(1)(f))	Processed strictly under the lawful instructions of the Tenant Controller
Primary Regulatory Role	Direct accountability to ICO for subscriber privacy rights	Bound by statutory Data Processing Addendum (DPA) under UK GDPR Art. 28

4.2 Data Subject Rights (DSR) & The Financial Retention Conflict

Under Chapter III of the UK GDPR, individuals possess fundamental privacy rights. However, in financial accounting, these rights interact directly with statutory company and tax laws. blynt resolves these interactions through precise legal mechanisms:

4.2.1 Right of Access (DSAR - Article 15)

- Data subjects can request a complete disclosure of their personal data.
- **SLA & Execution:** blynt provides an automated self-serve DSAR extraction tool allowing tenant administrators to generate a structured, password-protected JSON/PDF archive within **72 business hours** (well within the statutory 30-day requirement).

4.2.2 Right to Rectification (Article 16) vs. Accounting Integrity

- If personal data on a customer or supplier record is inaccurate, it can be updated in the subledger directory.
- **Accounting Invariant Safeguard:** Historical financial transactions cannot be rewritten. If an invoice contained an incorrect legal name or VAT registration number, the statutory correction must be executed via an official Credit Note and reissue, preserving audit trail validity under the Companies Act 2006.

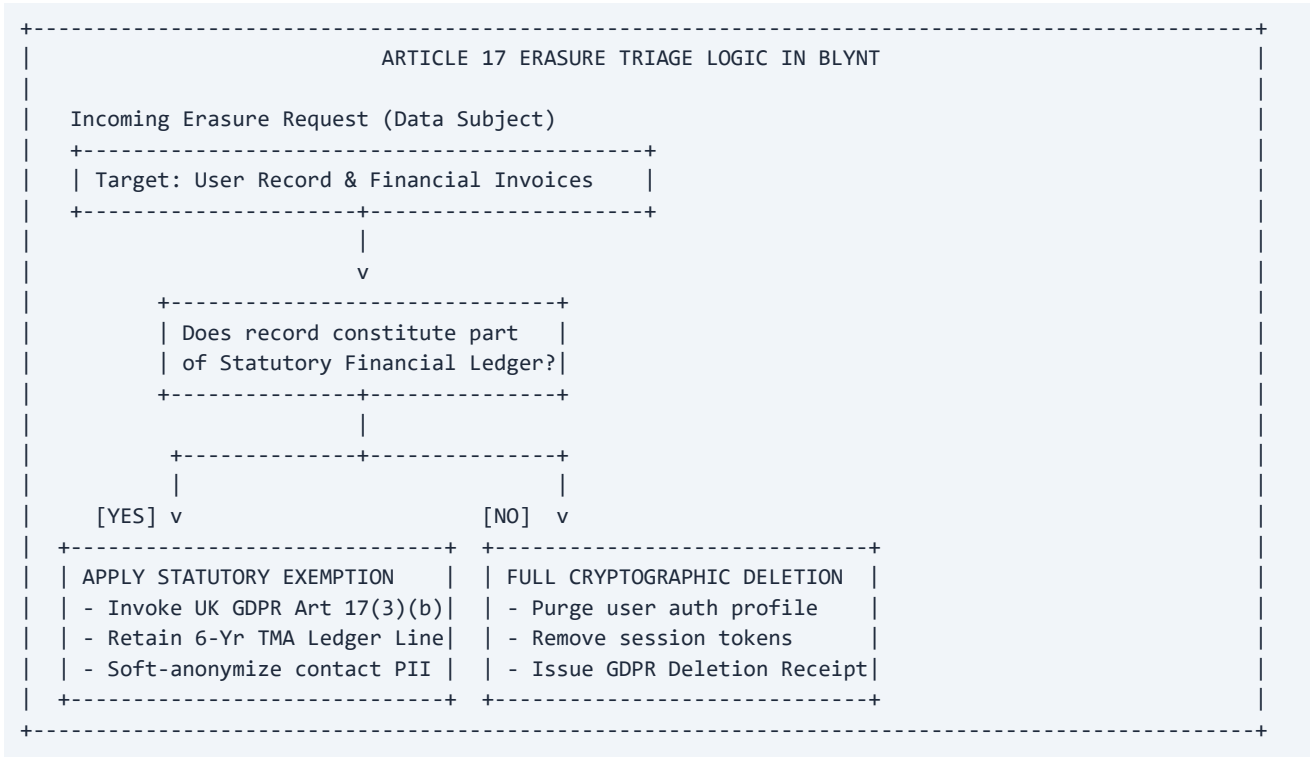
4.2.3 Right to Erasure ("Right to be Forgotten" - Article 17) vs. Statutory Retention Exemption

This represents the single most critical intersection between privacy law and financial regulation.

- **The Legal Exemption:** Under **Article 17(3)(b) of the UK GDPR**, the right to erasure does *not* apply to the extent that processing is necessary:

> *"for compliance with a legal obligation which requires processing by Union or Member State law to which the controller is subject..."*

- **Statutory Superiority:** Because Section 12B of the Taxes Management Act 1970 and Sections 386–388 of the Companies Act 2006 legally mandate the preservation of accounting vouchers and transaction records for 6 years, **blynt is legally prohibited from erasing posted journal lines or invoices during this statutory window**.
- **Technical Resolution (Soft Redaction):** In response to a valid Article 17 request, blynt anonymizes non-statutory personal identifiers (e.g., personal phone numbers, profile images, personal email addresses) while permanently retaining the immutable ledger line, transaction amount, VAT classification, and company tax registration number in accordance with statutory duty.



4.3 Records of Processing Activities (RoPA - Article 30)

In compliance with Article 30 of the UK GDPR, blynt maintains an up-to-date **Record of Processing Activities (RoPA)** documenting:

1. Contact details of the Controller, Processor, and Data Protection Officer (`dpo@blynt.io`).
2. Categories of data subjects (Customer employees, vendor contacts, subscriber administrators).
3. Categories of personal data (Names, email addresses, business addresses, IP addresses, bank account numbers).
4. Categories of recipients (AWS Cloud Infrastructure, HMRC API Gateway, Open Banking aggregators).
5. Cross-border international transfers and legal transfer mechanisms.
6. Statutory retention schedules (6 years for accounting data; 90 days for API debug logs).

7. General description of technical and organizational security measures (TOMs).

4.4 Data Protection Impact Assessments (DPIA - Article 35)

Whenever new platform features involve automated decision-making, optical character recognition (OCR) on financial documents, or integrations with third-party banking APIs, a formal **Data Protection Impact Assessment (DPIA)** is conducted by the Product Manager and reviewed by the DPO to evaluate privacy risks and implement mitigating controls before release.

4.5 International Data Transfers & Standard Contractual Clauses (SCCs)

All production databases and primary data processing facilities for blynt are hosted within the **United Kingdom (AWS eu-west-2, London)**.

- **Cross-Border Transfer Protections:** Where sub-processors operate outside the UK or European Economic Area (EEA), transfers are governed by the UK **International Data Transfer Agreement (IDTA)** or the EU Standard Contractual Clauses (SCCs) supplemented by formal Transfer Impact Assessments (TIAs) confirming adequate data protection equivalence.

4.6 72-Hour Personal Data Breach Escalation Protocol (Articles 33 & 34)

Under Articles 33 and 34 of the UK GDPR, personal data breaches must be identified, contained, assessed, and reported under strict legal timeframes:

```
+-------------------------------------------------------------------------------------------+
|                                72-HOUR ICO BREACH ESCALATION TIMELINE                     |
+---------------+---------------------------------------------------------------------------+
| Elapsed Time  | Mandatory Legal & Technical Milestone                                     |
+---------------+---------------------------------------------------------------------------+
| T = 0 Hours   | Security Incident Detected; P0 SIRT Team Activated; Immediate System Containment |
| T + 12 Hours  | Forensic Triage Complete; Nature of Compromised Personal Data Categorized       |
| T + 24 Hours  | DPO & General Counsel Risk Assessment: Likelihood of Harm to Individuals Evaluated|
| T + 48 Hours  | Formal Breach Notification Dossier Compiled (Root cause, impact, mitigations)   |
| T <= 72 Hours | Mandatory Formal Breach Notification Submitted to Information Commissioner (ICO) |
| Post-72 Hours | Notification dispatched to affected Data Controllers / Individuals without delay|
+---------------+---------------------------------------------------------------------------+
```

---

5. Contractual Protections, SaaS Terms of Service & SLA Guarantees

5.1 Enterprise SaaS Agreement Structure

All enterprise customer relationships are governed by the **blynt Master Services Agreement (MSA)** and incorporated schedules:

1. **Schedule 1: Service Level Agreement (SLA)** — Guaranteeing **99.95% monthly uptime** availability (excluding scheduled maintenance) with financial service credits scaling up to 25% of monthly fees in the event of SLA breach.

2. **Schedule 2: Data Processing Addendum (DPA)** — Binding blynt to statutory UK GDPR Article 28 processor obligations, confidentiality mandates, and sub-processor notification windows (minimum 30 days prior notice of new sub-processors).

3. **Schedule 3: Acceptable Use Policy (AUP)** — Prohibiting illegal financial transactions, money laundering, sanctions evasion, and unauthorized penetration testing against production nodes.

5.2 Limitation of Liability & Tax Disclaimer

- **Accounting Decision Autonomy:** The MSA explicitly affirms that while blynt provides high-precision automated calculation and validation tools, the customer's appointed company directors and certified accountants retain ultimate statutory responsibility under the Companies Act 2006 for the accuracy and completeness of statutory accounts and HMRC tax filings.
- **Liability Caps:** Aggregate liability is commercially balanced and capped at 12 months of paid subscription fees, excluding breaches of confidentiality, data protection indemnities, or gross negligence.

5.3 Exit Management & Cryptographic Offboarding

Upon termination of an enterprise subscription:

- **90-Day Transition Window:** The tenant maintains full read-only export access to download all historical journal lines, invoices, audit trails, and vouchers in standardized, open formats (JSON, CSV, PDF, and SAF-T compatible XML).
- **Cryptographic Destruction:** Following the transition window, tenant encryption keys in AWS KMS are permanently revoked, rendering all stored tenant ciphertext irrevocably unrecoverable across all storage tiers. A formal Certificate of Cryptographic Destruction is issued to the tenant.